SIMATS ENGINEERING
ASSESSMENT TOOL 3

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Scenario-Based Assessment

Topic 1: Footprinting Tools – Conducting Competitive Intelligence

Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

Task: Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

Topic 2: DNS Zone Transfers

Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

Code of Conduct:

I D.Hasini/192425147 *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: D.Hasini

ANSWERS

Q1. Passive footprinting of ABC Technologies - tools for domain details, employee e-mails, technology stack and subdomains, and their use in competitive intelligence. (15 Marks)

ABC Technologies is a case-study company, so the domain abctech.com is used below only as a placeholder for the company's real domain.

Understanding of Scenario (20%)

Passive footprinting means collecting information about a target from public sources and third-party databases, without sending any traffic to the target's own servers. The consultant must therefore avoid port scans, directory brute-forcing, zone-transfer attempts and any login attempt, and rely on registries, search engines, certificate logs and public data sets. **Competitive intelligence (CI)** is the legal gathering of information about an organization's structure, technology, partners and public presence to understand its strengths, weaknesses and security posture.

Identification of Key Issues (20%)

- **Domain registration details:** registrar, registration and expiry dates, name servers and (if not privacy-protected) registrant contacts.
- **Employee e-mail addresses:** the e-mail format and the people/roles the company exposes.
- **Technology stack:** web server, CMS, frameworks, hosting/CDN and third-party services used.
- **Publicly exposed subdomains:** portals, staging and admin sites that enlarge the attack surface.
- **Constraint:** every tool chosen must work from public data (passive mode) so that the assessment stays non-intrusive.

Application of Concepts (25%)

Information needed	Passive tools / sources	What they provide	Competitive-intelligence value
Domain registration	whois, ICANN lookup / RDAP, DomainTools, ViewDNS	Registrar, creation/expiry dates, name servers, organization and contacts, related domains	Shows company age, hosting and DNS providers, other domains owned (brands, subsidiaries)
Employee e-mails	theHarvester (passive sources), Hunter.io, Google dorks, LinkedIn	E-mail format (first.last@), role mailboxes, staff names and titles	Reveals organization structure, key departments and the social-engineering surface
Technology stack	BuiltWith, Wappalyzer, Netcraft, Shodan/Censys (stored data), job postings	Web server, CMS, JavaScript frameworks, CDN, analytics, mail provider, cloud services	Shows which technologies the competitor depends on and where outdated software may exist
Subdomains	crt.sh (certificate transparency), DNSDumpster, VirusTotal, SecurityTrails, Amass/Sublist3r in passive mode	Sub-domains such as portal, mail, vpn, dev, test and their IPs	Exposes products, internal projects and forgotten or poorly protected hosts
Supporting context	Google dorking, Wayback Machine, press releases, social media	Old pages, documents, metadata, announcements	Business plans, partners, past configurations

```
# Example commands (passive use)
whois abctech.com                          # domain registration details
theHarvester -d abctech.com -b duckduckgo,crtsh   # e-mails, sub-domains (public sources)
amass enum -passive -d abctech.com         # passive sub-domain enumeration
# crt.sh certificate-transparency search: https://crt.sh/?q=%25.abctech.com
# Online: BuiltWith / Wappalyzer / Netcraft for the technology stack
```

How each tool supports competitive intelligence: whois/RDAP identifies who owns and hosts the domain; theHarvester and Hunter.io map people and mail formats; BuiltWith/Netcraft profile the technology the company relies on; certificate and DNS data sets reveal the sub-domains and therefore the products and services behind them. Together they give a complete outside-in picture of the organization without touching its servers.

Decision Making (20%)

Passive methods are chosen because they are **legal, undetectable by the target and within the stated rule** of no direct interaction. Active techniques (port scanning, brute-forcing sub-domains) are deliberately rejected. The decision on which tool to use follows the question being asked: registry data for ownership, certificate logs for sub-domains, fingerprint databases for technology, and OSINT search for people. Findings are ranked by risk so that exposed login/staging sub-domains and the e-mail format are reported first.

Clarity of Response (15%)

Objective	Tool	Result type	Risk if misused
Domain details	whois / RDAP	Registrar, dates, name servers	Domain-hijack and phishing planning
E-mails	theHarvester, Hunter.io	Address list and format	Spear-phishing
Technology	BuiltWith, Wappalyzer	Software and versions	Targeted exploit selection
Subdomains	crt.sh, DNSDumpster, Amass (passive)	Host list	Attack on weak or forgotten hosts

Q2. Verifying DNS zone transfer (AXFR) permissions and using the retrieved records for reconnaissance. (15 Marks)

Understanding of Scenario (20%)

A DNS **zone transfer** (AXFR) copies the whole zone file of a domain from a primary DNS server to a secondary server, to keep them in sync. It should only be allowed to authorized secondaries. If the server answers any requester, the analyst receives every record of the zone - a complete map of the organization's hosts. In an authorized penetration test the analyst must check this misconfiguration and report its impact.

Identification of Key Issues (20%)

- The weakness is an **unrestricted allow-transfer** setting on the authoritative name server.
- The asset exposed is the DNS zone data: internal host names, IP addresses, mail servers, sub-domains and service records.
- The analyst first needs the authoritative name servers, because only they can answer a transfer request.

Application of Concepts (25%)

Step 1 - find the name servers: `dig ns example.com +short`. **Step 2 - request the zone transfer** from each name server:

```
dig ns example.com +short                    # authoritative name servers
dig axfr example.com @ns1.example.com        # request full zone transfer
# equivalent tools
host -t axfr example.com ns1.example.com
dnsrecon -d example.com -t axfr
fierce --domain example.com
```

Interpreting the result: if the transfer is *refused* ("Transfer failed" or REFUSED), the server is correctly restricted. If it *succeeds*, the output lists the SOA record, followed by every record in the zone and ends with the SOA again. **Illustrative sample of a successful transfer** (example data):

```
example.com.        3600 IN SOA  ns1.example.com. admin.example.com. ( ... )
example.com.        3600 IN NS   ns1.example.com.
example.com.        3600 IN MX   10 mail.example.com.
www.example.com.    3600 IN A    192.0.2.10
mail.example.com.   3600 IN A    192.0.2.25
vpn.example.com.    3600 IN A    192.0.2.30
dev.example.com.    3600 IN A    10.10.5.20     ; internal address leaked
db01.example.com.   3600 IN A    10.10.5.50
_ldap._tcp.example.com. 3600 IN SRV 0 100 389 dc01.example.com.
example.com.        3600 IN SOA  ns1.example.com. admin.example.com. ( ... )
```

How the retrieved records are used during reconnaissance:

Record type	What it reveals	Use in reconnaissance
A / AAAA	Host names and IP addresses, including internal ranges (for example 10.x.x.x)	Builds a list of internal hosts (dev, db01, vpn) and the IP scheme for scanning and targeting
MX	Mail servers and their priority	Identifies the mail gateway for phishing, spoofing and mail-server attacks
NS / SOA	Name servers and the admin contact	Locates other DNS servers and a responsible person for social engineering
CNAME	Aliases pointing to other services	Finds sub-domains, third-party services and possible subdomain takeover
TXT	SPF and verification strings	Shows allowed mail senders and cloud services in use

Record type	What it reveals	Use in reconnaissance
SRV	Service locations (LDAP, Kerberos, SIP)	Reveals domain controllers and internal services

Decision Making (20%)

A successful transfer is rated **high severity**: it removes the attacker's need for guessing and gives a map for targeted attacks, particularly if internal addresses and development hosts appear. The decision is to report it as a critical misconfiguration, with the immediate fix: restrict *allow-transfer* to the IP addresses of the secondary servers, protect transfers with TSIG keys, use split-horizon DNS so that internal names are not in the public zone, remove stale records, and monitor logs for AXFR attempts. A failed transfer is reported as a pass for this control.

Clarity of Response (15%)

The report lists: objective, authorization, commands used, result (success or refused), the records obtained, the reconnaissance use of each record type, the risk rating and the remediation steps.

Q3. E-mail from “IT department” asking employees to verify login credentials through a link because of an urgent security update. (20 Marks)

Understanding of Scenario (20%)

Employees receive an unexpected e-mail that appears to come from their own IT department. It says there is an urgent security update and instructs them to “verify” their credentials by clicking a link. The scenario describes a well-known deception technique: the attacker pretends to be a trusted internal authority and uses urgency and fear to make people act without thinking. The goal of the message is to obtain usernames and passwords, which can then be used to enter the organization’s systems.

Identification of Key Issues (20%)

- **Attack type: Phishing** (e-mail based social engineering), specifically a **credential-harvesting** attack. Because it is sent to many employees it is **mass (bulk) phishing**; if it used personal details it would be spear phishing.
- **Techniques used:** impersonation of IT (pretexting and authority), **urgency/fear** (“urgent security update”), a malicious link to a fake login page, and a request that real IT departments never make (asking for passwords by e-mail).
- **Warning signs:** unexpected message, generic greeting, a sender address or domain that does not exactly match the company, a link whose real destination differs from the text, pressure to act at once, possible spelling errors.
- **Vulnerability exploited:** human trust and lack of verification, helped by weak mail filtering and the absence of multi-factor authentication.

Application of Concepts (25%)

Countermeasures employees should apply before responding:

- **Stop and think:** do not act under pressure; urgency is a warning sign.
- **Check the sender:** expand the sender’s full e-mail address and domain; look for look-alike domains or spoofed display names.
- **Inspect the link without clicking:** hover over it to see the real URL; do not use shortened or unfamiliar links.
- **Never enter credentials through an e-mailed link:** go to the official portal by typing the address yourself or using a saved bookmark.
- **Verify through a second channel:** call or message the IT helpdesk on the known official number or ticketing system.
- **Do not open attachments or reply** to the message.
- **Report it:** use the “Report phishing” button or forward to the security team, then delete it.
- **If already clicked or entered a password:** change the password immediately, tell IT security, and watch for suspicious account activity.

How these actions prevent credential theft: credentials are stolen only when the user types them into the attacker’s fake page. Checking the sender and the link exposes the fake before that happens; navigating to the official site yourself bypasses the malicious link; verifying with IT confirms whether the request is genuine; reporting alerts the security team so that the message can be removed from every mailbox and the domain blocked; and a fast password change makes any captured password useless.

Supporting organizational controls: multi-factor authentication (a stolen password alone is not enough), a password manager (it will not auto-fill on a fake domain), SPF/DKIM/DMARC, mail gateway with URL protection, awareness training and phishing simulations.

Decision Making (20%)

Situation	Decision	Rationale
Unexpected IT mail asking for credentials	Do not click; do not reply	Real IT teams never request passwords through e-mail links
Sender or link looks doubtful	Report to security and delete	Protects colleagues; lets IT block the sender/domain
Genuinely unsure	Verify via the official helpdesk number	A second channel confirms legitimacy
Already entered credentials	Change password, inform IT, check account	Limits the time the attacker can use the stolen password

The correct decision rule is **“when in doubt, do not click - verify and report”**. The cost of a short verification is small compared with the cost of a compromised account, data breach and lost trust.

Clarity of Response (15%)

Item	Summary
Attack type	Phishing (credential harvesting, mass phishing) using impersonation, authority and urgency
Employee actions	Pause, check sender, inspect link, use official portal, verify with IT, report, change password if exposed
Why it works	The fake page is never reached, so no credentials are typed; the report removes the threat for everyone

RUBRICS FOR CALCULATION

Scenario Based Assessment

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand